

Guía Metodológica de la Encuesta NIST CSF 2.0

Diseño, aplicación, análisis y uso de resultados

1. Propósito de la encuesta

La presente encuesta tiene como objetivo medir el grado de adopción, madurez y capacidad de medición (KPIs/KRIs) en materia de ciberseguridad de organizaciones ubicadas en España, tomando como referencia el NIST Cybersecurity Framework 2.0 (NIST CSF 2.0) y marcos normativos relacionados.

Busca, además, proporcionar una base cuantitativa para calcular un Índice Global de Madurez (IGM) y estimar el retorno de la inversión (ROI) en iniciativas de ciberseguridad.

2. Marco conceptual

La encuesta se estructura alrededor de las seis funciones del NIST CSF 2.0:

- GOVERN (GV) – Estrategia, gobernanza, roles, apetito de riesgo.
- IDENTIFY (ID) – Activos, contexto de negocio, riesgo, datos.
- PROTECT (PR) – Controles preventivos, acceso, formación, protección de datos.
- DETECT (DE) – Monitorización, detección de eventos e incidentes.
- RESPOND (RS) – Respuesta, gestión de incidentes, comunicación.
- RECOVER (RC) – Recuperación, continuidad, resiliencia.

Se añaden explícitamente preguntas sobre:

- Gestión de cadena de suministro (GV.SC).
- Prácticas de medición, cuadros de mando y ROI (métricas y analítica).

3. Población objetivo y muestreo

3.1. Población objetivo

- Organizaciones con presencia significativa en España:
- Administración pública (AGE, CCAA, EELL, organismos independientes).
- Operadores de servicios esenciales y entidades sujetas a NIS/NIS2.
- Entidades financieras y otras obligadas por DORA.
- Empresas privadas medianas y grandes.

3.2. Perfil de los encuestados

Se recomienda que respondan:

- CISO, responsable de seguridad de la información, responsable de riesgos TI o equivalente.
- En su defecto, perfiles de alta dirección de TI (CIO) o gerencia con conocimiento suficiente del programa de seguridad.

4. Diseño del cuestionario

4.1. Tipología de preguntas

- Preguntas cerradas de opción única, formuladas como escalas de madurez o frecuencia.
- Preguntas de opción múltiple para identificar prácticas simultáneas.
- Preguntas abiertas para recoger percepciones, barreras y aspiraciones.

Las opciones de respuesta se formulan con un tono ligeramente irónico pero respetuoso, para favorecer la auto-reflexión y evitar el exceso de complacencia.

4.2. Escalas de madurez sugeridas

Se sugiere mapear las opciones de respuesta a una escala interna numérica, por ejemplo:

- 0 = Inexistente / ad hoc / no se realiza.
- 1 = Inicial / informal / muy parcial.
- 2 = Definido / en despliegue / cobertura moderada.
- 3 = Estable / repetible / ampliamente aplicado.
- 4 = Optimizado / gestionado por métricas / integrado.

Cada pregunta cerrada se codifica con un valor de 0 a 4 según el nivel de madurez implícito en la opción elegida.

5. Cálculo del Índice Global de Madurez (IGM)

5.1. Normalización por función CSF

1. Asignar a cada respuesta cerrada un valor numérico de 0–4.
2. Agrupar las preguntas por función (GV, ID, PR, DE, RS, RC, SC, métricas/ROI).
3. Para cada función, calcular el promedio simple o ponderado de los valores de sus preguntas.

Ejemplo:

- GV_madurez = promedio de P-GV-01 a P-GV-08.

- ID_madurez = promedio de P-ID-01 a P-ID-07.

- Etc.

5.2. Cálculo del IGM

El IGM se calcula como el promedio (simple o ponderado) de las funciones:

$$\left[\text{IGM} = \frac{\text{GV} + \text{ID} + \text{PR} + \text{DE} + \text{RS} + \text{RC} + \text{SC} + \text{ME}}{8} \right]$$

donde ME representa métricas/ROI.

La escala resultante puede expresarse:

- 0,0 – 0,9 – Nivel 1: Inicial / ad hoc.
- 1,0 – 1,9 – Nivel 2: Básico / fragmentado.
- 2,0 – 2,9 – Nivel 3: Definido / en despliegue.
- 3,0 – 3,4 – Nivel 4: Gestionado / repetible.
- 3,5 – 4,0 – Nivel 5: Optimizado / integrado.

Se recomienda ajustar estas bandas en función de la distribución real de respuestas.

6. Enfoque para el ROI

6.1. Variables recomendadas

- Costes anuales de ciberseguridad (OPEX + CAPEX).
- Estimación de pérdidas evitadas (o reducidas) por incidentes mitigados.
- Reducción de exposición al riesgo (p.ej., pérdidas esperadas monetizadas).
- Impacto en cumplimiento normativo (p.ej., reducción de probabilidad de sanciones).

6.2. Fórmulas simplificadas

Se puede emplear una aproximación básica:

$$\left[\begin{array}{l} \text{ROI}_{\text{ciber}} = \frac{\text{Beneficios estimados} - \text{Costes de ciberseguridad}}{\text{Costes de ciberseguridad}} \end{array} \right]$$

donde los beneficios incluyen reducción de pérdidas esperadas, de sanciones, de tiempo de indisponibilidad y otros factores cuantificables.

La plantilla de Excel recomendada (descrita en el documento e_plantilla_igm_roi.md) incluye campos para que la organización introduzca:

- Costes.
- Incidentes antes/después.
- Reducción de tiempos (MTTD, MTTR, RTO).
- Estimaciones monetarias asociadas.

7. Aplicación de la encuesta

7.1. Modalidad

- Preferentemente online, mediante formulario estructurado que refleje la encuesta.
- Alternativamente, mediante entrevistas semiestructuradas guiadas por este cuestionario.

7.2. Duración

- Objetivo: 20–30 minutos.
- Incluir instrucciones claras y contexto sobre uso de datos y confidencialidad.

7.3. Confidencialidad

- Garantizar anonimato o seudonimización de los resultados agregados.
- Comunicar explícitamente si se compartirán resultados individuales con terceros.

8. Análisis de resultados

8.1. Análisis descriptivo

- Distribución de madurez por función CSF.
- Comparación por tipo de organización (pública/privada, sector, tamaño).
- Identificación de dominios más y menos maduros.

8.2. Análisis de correlaciones

Explorar relaciones, por ejemplo:

- Madurez en GOVERN vs. madurez global.
- Impacto de métricas/ROI (ME) en otros dominios.
- Relación entre tamaño de organización y nivel de madurez.

8.3. Benchmarking

- Cálculo de percentiles por función.
- Posicionamiento de cada organización (si se desea) respecto a medianas de su sector.

9. Utilización de resultados

- Para la organización individual:
 - Identificar brechas y prioridades de mejora.
 - Comunicar al comité de dirección la posición relativa.
- Para el nivel sectorial/nacional:
 - Alimentar indicadores agregados de resiliencia.
 - Apoyar la planificación de políticas públicas y programas de ayuda.

Comunicar al comité de dirección la posición relativa.

Para el nivel sectorial/nacional:

10. Recomendaciones finales

- Mantener la encuesta estable en el tiempo para permitir comparaciones longitudinales.
- Revisar el cuestionario a la luz de nuevas versiones del NIST CSF, normativa europea y española.
- Fomentar una lectura constructiva de los resultados: no se trata de suspender a nadie, sino de medir para mejorar.